

SLOVPACK s.r.o. — Client Evidence Pack

Purpose of this document. This evidence pack contains the simulated source material for the SLOVPACK ISO/IEC 27001:2022 implementation lab — the inputs a consultant would gather during a real engagement: interview notes, contract extracts, an asset inventory, an incident record, a site walkthrough and a customer security questionnaire. Every ISMS artefact in this portfolio (context analysis, risk register, Statement of Applicability, policies, audit findings) is derived from the evidence below and references it by code (E01–E14).

DISCLAIMER: SLOVPACK s.r.o. is a fictional company. All persons, companies, data and events in this evidence pack are invented for portfolio purposes.

E01 — Company Dossier and Org Chart

Source: managing director's assistant, e-mail 12 Jan 2026

SLOVPACK s.r.o. — founded 2009. Manufactures and distributes packaging solutions (cardboard boxes, foil packaging, labels). HQ and production: Bratislava-Rača. Warehouse: Senec (leased). 45 employees, ~300 B2B customers (SK/CZ/AT), turnover ~€6.2M (2025). Key customers: **PharmaVital a.s.** (SK, pharma), **MediPack GmbH** (AT, pharma), and food-industry clients.

Org chart:

- **Peter Kováč** — Managing Director
 - **Katarína Bielíková** — Head of Sales (8 staff, 5 mostly remote/field)
 - **Roman Čech** — Head of Production (22 staff, production hall BA)
 - **Ľubomír Hruška** — Head of Logistics (7 staff, Senec warehouse)
 - **Jana Šimková** — Finance & HR Manager (4 staff, incl. accountant **Eva Molnárová**)
 - **Marek Urban** — IT Administrator (single-person IT function)
 - **Quality & Compliance** (2 staff) — includes the ISMS Manager role

External suppliers: NetAdmin Solutions s.r.o. (MSP — servers, network), WebFront Digital s.r.o. (e-shop development), HostPoint SK (e-shop VPS hosting), LogisSoft (WMS vendor), PayWell (cloud payroll software).

E02 — Interview: Peter Kováč (Managing Director)

On-site, HQ meeting room, 14 Jan 2026, 09:00–10:15.

1. **Reason for the project:** PharmaVital sent a security questionnaire (see E14) and stated that without ISO 27001 or a demonstrable security system they will not renew the framework contract from 2027. MediPack is asking too. This represents about one third of turnover.
 2. **Top concern:** Production recipes and specifications — 15 years of proprietary know-how. If leaked to a competitor it would be existential. Currently almost the whole production team can see them in the ERP, which he acknowledges is wrong.
 3. **Budget:** Willing to invest but not extravagantly ("we're a factory, not a bank"). Purchases above €2,000 require his approval.
 4. **Continuity:** Last summer a 6-hour outage of the warehouse link halted dispatch; retailer penalties make this unaffordable to repeat.
 5. **Responsibilities:** Never formally defined — "security is Marek's job, I think?" No information security policy exists.
 6. **Incidents:** Recalls "some fraudulent e-mail last year in accounting" — no details, "it was resolved quietly."
 7. Declared full support: will sign the policy, attend management review, communicate importance to staff.
-

E03 — Interview: Marek Urban (IT Administrator)

On-site plus server-room walkthrough, 15 Jan 2026, 08:30–11:00.

1. **Role:** Sole internal IT ("I do everything from toner to ERP; when I'm on holiday we cross fingers"). Infrastructure documentation is "mostly in my head, some in OneNote."
2. **M365:** Business Premium, 45 licences. **MFA enabled only for the admin account (his); standard users NOT** — "people complained so we turned it off, I meant to finish it." Default spam filter only.
3. **ERP "OptiFlow":** On-premise, 2 physical servers (app + DB), Windows Server 2016. **Patching: "when there's time," no schedule.** ERP permissions "grew historically, never cleaned up — production sees all recipes, sales sees all customer and margin data." Access review never performed.
4. **Network:** Flat — a single LAN for offices, production and servers, no segmentation. Perimeter firewall managed by NetAdmin. Site-to-site VPN to Senec (single link, no backup).
5. **Backups:** "Runs daily to a NAS and some goes to cloud, NetAdmin set it up. **We have never tested a restore**, I admit."
6. **Endpoints:** 28 laptops, 12 desktops, 6 shared production terminals — **terminals run Windows 7** (tied to legacy cutter software). Laptops: **BitLocker on ~half only**; no MDM. Antivirus: Defender.
7. **Logs:** "ERP has some logs, M365 default. Nobody monitors them, we have no tool or time." Asked whether he could investigate who exported the recipes: "Honestly? Probably not."

8. **USB:** Private USB sticks are routinely used in production to move drawings to the cutter.
 9. **Domain and DNS:** slovpack.sk is registered under Marek's **personal account** at the registrar ("historically; I still pay for it on the company card").
 10. **Server room:** see E13.
 11. **Passwords:** "There's some 2019 directive (E11) but nobody follows it."
-

E04 — Interview: Jana Šimková (Finance & HR Manager)

Remote, MS Teams, 16 Jan 2026, 13:00–14:00.

1. **HR data:** Personnel files in a locked cabinet plus digital copies in a SharePoint "HR" folder — **the whole finance department (4 people) has access**, although only she and Eva process payroll. Payroll software PayWell (cloud, separate login, no MFA).
 2. **GDPR:** "We have some consents and a 2018 lawyer's directive. **Records of processing activities? That means nothing to me.**"
 3. **Onboarding:** NDA signed within the employment contract. Security training: none. Access granted by Marek "based on what I e-mail him."
 4. **Offboarding:** "I e-mail Marek, he disables the accounts **when he gets to it — realistically within 2–3 days**. Keys and laptop are returned to me, but we keep no list of what each person holds."
 5. **2025 incident:** Confirmed the phishing details (E12). "It was embarrassing, Eva felt bad, so we left it. We never reported it to the authorities or police — should we have?"
 6. **Invoices:** Payments entered by Eva, approved by Jana, and above €5,000 also by Peter. Supplier bank-account changes are verified "usually by phone, when we remember."
-

E05 — Interview: Ľubomír Hruška (Head of Logistics)

On-site, Senec warehouse, 20 Jan 2026, 10:00–11:30.

1. **WMS (LogisSoft):** 7 warehouse workers across 3 shifts use **3 shared accounts** ("the licence is per user and expensive, so we worked around it"). Passwords written in marker on the dispatch monitor.
2. **VPN outage summer 2025:** 6 hours without ERP connection — dispatch halted, "we caught up on paper into the night." No written fallback procedure exists, "we keep it in our heads."
3. **Warehouse physical security:** Fenced site owned by the landlord, daytime gatekeeper, night alarm, CCTV on the loading docks (landlord-managed, 14-day retention).

4. **Laptops:** 2 units in the warehouse office, kept locked. Workers do not connect personal devices to the WMS.
 5. High warehouse staff turnover (3–4 leavers a year) — another reason accounts are shared ("to avoid constantly creating new ones").
-

E06 — Interview: Katarína Bieliková (Head of Sales)

Remote, MS Teams, 21 Jan 2026, 09:00–10:00.

1. **Sales work:** 5 of 8 sales staff are mostly in the field/remote. Company laptops and phones. They connect via M365; the VPN to the ERP "is annoying, so we **throw larger files through a private Dropbox** — price lists, drawings, sometimes contracts."
 2. **E-shop:** B2B portal (orders, customer-specific pricing). Developed and managed by WebFront Digital, hosted by HostPoint SK. "When it goes down we call WebFront. Penetration test? I don't know what that is, so probably not."
 3. **Customer data:** Contracts and price lists in the ERP plus copies in e-mail and Dropbox. Individual pricing is sensitive ("if customer A saw customer B's prices we'd have a problem").
 4. **Mobiles:** Company-owned but unmanaged (each person manages their own), e-mail configured on all of them.
-

E07 — Phone call: Ivan Sedlák (NetAdmin Solutions, MSP)

Call notes, 22 Jan 2026, 15:00–15:40.

1. **Scope of services:** Management of servers, firewall, VPN and backups. Remote **administrative access to the whole infrastructure** via their own RMM tool; their technicians (4 people) share the RMM credentials for SLOVPACK.
 2. **Backups:** Daily incremental plus weekly full to a NAS in the server room, plus a copy to their cloud. **"Restore test? That's not in your contract, we only do it on request, chargeable."** The NAS is permanently connected to the network (no offline/immutable copy).
 3. **Server patch management:** "We apply critical patches quarterly, if operations allow." Windows 7 terminals: "We know about them; we recommended replacement in 2023 but it was never approved."
 4. **Incident notification:** The contract contains no obligation to report security incidents on their side. SLA: response within 8 working hours.
 5. Willing to add services (restore tests, monitoring) for an additional fee — will send a quote.
-

E08 — IT Asset Inventory Export (from Marek, extract)

Excel "inventar_2025_v3.xlsx", last updated 11/2025

#	Device / System	Qty	OS / version	Note
1	Server APP01 (OptiFlow app)	1	Win Server 2016	physical, HQ server room
2	Server DB01 (OptiFlow DB, file server)	1	Win Server 2016	physical, HQ server room
3	NAS (backups)	1	—	HQ server room, managed by NetAdmin
4	Firewall/router	1	—	managed by NetAdmin
5	Laptops	28	Win 11/10	BitLocker ~50 %, no MDM
6	Desktops	12	Win 10	offices
7	Production terminals	6	Win 7	shared, cutter software
8	Mobiles (sales)	8	Android/iOS	unmanaged
9	WMS server	1	hosted by LogisSoft	access via VPN
10	M365 tenant	1	—	45 users
11	E-shop (WooCommerce)	1	HostPoint VPS	managed by WebFront
12	PayWell (payroll)	1	cloud SaaS	2 users
13	Domain slovpack.sk + DNS	1	—	personal account of M. Urban

E09 — Contract Extract: NetAdmin Solutions s.r.o.

"IT Services Agreement", signed 03/2019, addendum 01/2022

- Art. 3: Scope — management of servers, network infrastructure, data backup.
- Art. 5: SLA — response within 8 working hours, business days 08:00–17:00.
- Art. 7: Confidentiality — mutual, standard NDA clause.

- **Entirely missing:** obligation to report security incidents, right to audit, requirements for technician access management, backup restore testing, return/deletion of data on termination, sub-contractor disclosure.

E10 — Contract Extract: WebFront Digital s.r.o.

"Work and Service Agreement — B2B portal", 06/2021

- Development, maintenance and hosting management of the e-shop; monthly retainer.
 - Art. 6: Test environment — "The contractor uses a test environment with anonymised/synthetic data; production personal data is not copied into tests." (*the one positive finding*)
 - **Missing:** secure development requirements (secure coding), security testing obligation, incident reporting, e-shop backup, ownership and handover of source code on termination.
-

E11 — Internal Password Directive (2019) — full text

"Directive 2/2019 on computer passwords", signed by P. Kováč, 04/2019

1. A password must be at least 6 characters long.
2. Passwords must be changed every 30 days.
3. Passwords must not be written on paper near the computer.
4. Every employee is responsible for compliance.

Note from interviews: nobody follows it; Marek is aware of it, Jana was unsure whether it still applies. It conflicts with modern practice (30-day rotation is outdated, 6 characters insufficient).

E12 — Incident Record: Phishing 10/2025

Reconstructed from e-mails and interviews with J. Šimková and E. Molnárová

- 14 Oct 2025, 10:42 — accountant Eva Molnárová received an e-mail impersonating the MD ("PETER KOVAC p.kovac@slovpac-sk.com" — spoofed domain), urgently requesting payment of €11,400 to a "new supplier".
- Eva clicked the HTML attachment and entered her M365 credentials on a fake login page. She did NOT make the payment — a Lithuanian account number made her suspicious and she called Jana.
- Marek blocked the account and reset the password the same day. **Not investigated:** whether the attacker used the access, set up forwarding rules, or logged in (nobody examined the logs).

- Not reported: not to management formally, not to the Data Protection Office, not to police. No record kept, no lessons shared. MFA was NOT enabled after the incident.
-

E13 — Site Walkthrough Notes

HQ Bratislava 15 Jan 2026 (with M. Urban), Senec warehouse 20 Jan 2026 (with Ľ. Hruška)

HQ server room: A 2×3 m room on the ground floor next to the kitchenette. **Door unlocked** ("we lock it when we remember; the key hangs on the board in the kitchen"). Air-conditioning works. **UPS present, last service/test unknown** (inspection sticker 2021). Fire extinguisher in the corridor. Cabling partially labelled. The backup NAS is in the same room as the servers (single location plus MSP cloud copy). **HQ offices:** Free movement, visitors not logged ("reception knows who comes in"). Contracts and price lists left openly on desks. Screens not locked. **Senec warehouse:** see E05 — fencing, gatekeeper, alarm, landlord CCTV. WMS passwords on the monitor (photographed as evidence).

E14 — Customer Security Questionnaire from PharmaVital a.s. (extract)

Received 8 Jan 2026, completion deadline 30 Jun 2026 — the trigger for the whole project

Selected questions (of 42):

1. Do you have a management-approved information security management system (ISMS)? To which standard?
2. Please attach your information security policy and a list of roles and responsibilities.
3. Do you perform regular risk assessments? Please attach your methodology.
4. How do you manage access to confidential information (production specifications, contracts)? Do you perform regular access reviews?
5. Do you have a security incident management process, including customer notification within 24 hours?
6. How do you secure your sub-contractors (IT services, hosting)?
7. Do you regularly test the restoration of backups of critical systems?
8. Do you perform internal security audits? Please attach the latest report.
9. Do you plan ISO/IEC 27001 certification? On what horizon?